

Shodan

: 인터넷에 공개된 디바이스·서비스 스캐닝 정보 플랫폼

✓ 보안 관점에서 어떻게 쓰나?

1. 조직/회사 소유 자산이 인터넷에 노출되어 있는지 확인
2. 특정 포트가 열려 있거나, 버전이 낡은 서비스가 자동으로 노출되는지 점검
3. IoT 장치·CCTV·DB 서버 등 의도치 않은 외부 노출 여부 검증

✓ 방어자가 점검할 수 있는 사항

1. 외부에서 접근 가능한 포트 목록 확인
2. 서비스 배너(Service Banner) 노출 여부 파악

****서비스 배너** : 특정 네트워크 서비스가 연결 요청에 응답할 때 자동으로 전송하는 식별 정보 메시지

3. 오래된 버전(CVE 존재 여부) 점검
4. 디바이스가 공공 인터넷에 노출되면 안 되는지 판단

Shodan의 작동 방식

Shodan은 일반적인 검색 엔진처럼 웹을 크롤링하는 것이 아니라, 특정 포트를 대상으로 인터넷에 연결된 모든 장치에 지속적으로 연결 요청을 보냅니다.

1. 포트 스캐닝: 다양한 TCP/IP 포트(21, 22, 23, 80, 443, 8080 등)를 스캔합니다.
2. 배너 그라빙: 장치가 응답할 때 보내는 '배너(**Banner**)' 정보(예: "Apache/2.4.6 (CentOS)" 또는 "Hikvision IP Camera")를 수집합니다.
3. 데이터베이스 구축: 수집된 배너 정보, IP 주소, 지리적 위치 등을 바탕으로 장치 유형별 데이터베이스를 구축하여 사용자가 검색할 수 있게 합니다.

공격 매커니즘

1. 검색 : 비밀번호가 없거나, 기본 비밀번호를 사용하는 기기의 배너특징 검색
2. 식별 : 특정 버전의 취약점(CVE)이 있는 기기리스트 확보
3. 접근 : 검색된 IP로 접속하여 제어권을 탈취 or 봇넷의 좀비로 만듦